

## **Bound Value Capability**

The Bound Value Validation design uses bound values to perform runtime validation that ensures application fail-safe processing and reliably generate log message. For example, by establishing a bound value of 64 characters length for log message string argument, the design checks and verifies that string arguments do not exceed 64 characters. This mitigates potential faults where string value is not properly NULL terminated.

Bound Value Validation ensures that the API functions are robust, reliable and prevent faults or abnormal behavior from impacting the application execution processing flow. For example, if any of the API fails validation it simply logs an error code and returns, allowing the application to continue normal processing.

*The goal is to minimize C/C++ programming flaws and program execution faults from causing the application to crash. In a few cases, it is possible to prevent the application from crashing, but not guarantee the data used is correct (e.g., use of an invalid data pointer).*

Detailed programming examples on how some of the Bound Argument Validation works are provided in the `WandISSAL-examples.c` program.

| <b>Growing list of Bound Value Validations and mitigation</b> |                                                                                                |                                                                                                                                                                             |
|---------------------------------------------------------------|------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Definition</b>                                             | <b>Values</b>                                                                                  | <b>Benefits</b>                                                                                                                                                             |
| Select generation of output log message.                      | Generate both development and production log messages together or only production log message. | Reduce generating unnecessary development log messages used during code development in a production environment.                                                            |
| Number of format string specifiers types per log message      | Maximum number of format string specifiers types allowed per message is 6.                     | Verify that log message arguments do not exceed an unreasonable number of arguments.                                                                                        |
| Types of format string specifiers.                            | Different types of supported format string specifiers are %s, %d, %f, %c, %x, %p.              | Prevent use of format spring specifiers not in the list and block attacker malicious specifier format.<br><br>Align string specifier type with corresponding argument type. |

|                                                                                                                           |                                                         |                                                                                                             |
|---------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| Passing NULL or 0 to %s:<br><b>char *name = NULL;</b><br><b>printf("Name = %s\n",*name);</b>                              | Prevent use of NULL or 0 values for %s.                 | Avoid abnormal behavior or segmentation fault.                                                              |
| Passing negative value to (instead of a pointer) %s:<br><b>printf("Name = %s\n",-1);</b>                                  | Prevent use of negative value for %s.                   | Avoid segmentation fault.                                                                                   |
| Passing invalid integer value to (instead of a pointer) %s:<br><b>int num = 10;</b><br><b>printf("Name = %s\n", num);</b> | Prevent use of invalid integer value for %s.            | Avoid segmentation fault.                                                                                   |
| Passing a single char for %s:<br><b>char letter = 'A';</b><br><b>printf("Name = %s\n", letter);</b>                       | Prevent the use of char for %s.                         | Avoid segmentation fault.                                                                                   |
| Passing a string for %c:<br><b>char *str = "STR";</b><br><b>printf("Name = %c\n", str);</b>                               | Prevent the use of string for %c.                       | Avoid segmentation fault.                                                                                   |
| Dereferencing the pointer inside printf():<br><b>char *str = "STR";</b><br><b>printf("Name = %s\n",*str);</b>             | Prevent dereferencing pointer inside printf().          | Avoid segmentation fault.                                                                                   |
| Using %n leads to format string vulnerability and memory overwrite.<br><b>printf("%1000u%n", 1, &amp;my_var);</b>         | Prevent the use of %n.                                  | Avoid for vulnerability coding and segmentation fault.                                                      |
| Unchecked dynamic input formats of "%s%s%s":<br><b>scanf("%99s", user_input);</b><br><b>printf(user_input);</b>           | Prevent unchecked dynamic input formats of "s%s%s".     | Avoid segmentation fault.                                                                                   |
| Length for string arguments.                                                                                              | Maximum length for %s string argument is 64 characters. | Avoid abnormal behavior due to unbounded, invalid string length or improperly NULL terminated string value. |

|                                                                                 |                                                                                                                                                                  |                                                                                                                                                                |
|---------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Length for message format string specification.                                 | Maximum length format string specification is 256 characters.                                                                                                    | Avoid abnormal behavior due to unbounded, invalid string length or improperly NULL terminated string value.<br><br>Avoid string specification buffer overflow. |
| Subset of ASCII characters for format string specification and string argument. | Fixed subset of ASCII characters allowed:<br>upper/lower case alphanumeric, blank and \\<br>%%, \', \", and<br>!#\$%&'()*+,-<br>./:;<=>?@[ ]^_{~ }<br>characters | Avoid characters not needed for message logging, such as non-printable characters.                                                                             |
| Number of severity id=value pairs and length of value string.                   | Maximum number of severity levels is 4 and length of string value is 16 characters.                                                                              | Allow use of valid pre-defined severity levels.                                                                                                                |
| Number of logical message grouping id=value pairs and length of value string.   | Maximum number of logical message groups is 32 and length of string value is 16 characters.                                                                      | Allow use of valid pre-defined logical message groups.                                                                                                         |
| New line at the end of log message.                                             | Add \n at the end of each log message.                                                                                                                           | Never forget to add new line at the end of string specification.                                                                                               |